
The State of OpenClaw Security:
Threats, Vulnerabilities, and the Case
for Continuous Agent Hardening

February 2026

clawscan.app

This unprecedented capability comes with unprecedented risk. Within its first month of widespread adoption, OpenClaw has been associated with:

- CVE-2026-25253 (CVSS 8.8): One-click remote code execution via cross-site WebSocket hijacking
- 512 vulnerabilities identified in a comprehensive audit, 8 classified as critical
- 21,639 publicly exposed instances discovered by Censys, many without authentication
- 341 malicious skills (12% of ClawHub) distributing keyloggers and info-stealers
- 35,000 email addresses and 1.5M API tokens leaked from the Moltbook breach
- Nation-state warnings from China's CNCERT citing "significant security risks"

The agentic AI security landscape has shifted from theoretical to existential. OpenClaw is the canary in the coal mine for every autonomous AI deployment.

OpenClaw (originally Clawdbot, then Moltbot after trademark disputes with Anthropic) was created by Austrian developer Peter Steinberger and launched in December 2025. It went viral almost immediately -- users flooded social media with photos of Mac mini stacks, configuration screenshots, and bot interactions.

KEY ADOPTION METRICS:

- 135,000+ GitHub stars (one of the fastest-growing repos ever)
- 180,000+ estimated active deployments
- 6,000+ community-built skills on ClawHub
- Mac mini shortages in U.S. retail stores
- Andrej Karpathy publicly endorsed and purchased hardware for it
- DigitalOcean, Hostinger launched 1-click deploy images

But this capability creates a fundamental tension: the features that make OpenClaw powerful are the same features that make it dangerous. Full system access, persistent memory, autonomous execution, and broad tool permissions create an attack surface unlike anything the security community has previously encountered.

As Cisco noted: "Granting an AI agent unlimited access to your data -- even locally -- is a recipe for disaster if any configurations are misused or compromised."

The question is no longer whether open agentic platforms work. It's whether the security model can keep pace with adoption.

Patched in version 2026.1.29, but thousands of instances remained vulnerable during the disclosure window.

Attackers uploaded 341 malicious skills to ClawHub -- 12% of the entire registry of 2,857 skills. They used professional documentation and names like "solana-wallet-tracker" and "productivity-assistant" to appear legitimate.

Once installed, they executed external code deploying keyloggers on Windows and Atomic Stealer malware on macOS. The attack exploited ClawHub's complete lack of moderation for skill uploads.

This represents a new attack class: AI agent skill poisoning.

Censys identified 21,639 publicly accessible OpenClaw instances on January 31, up from ~1,000 days earlier. 30% of Chinese instances ran on Alibaba Cloud.

Researcher @fmdz387 found ~1,000 instances without any authentication. Researcher Jamieson O'Reilly accessed Anthropic API keys, Telegram bot tokens, Slack accounts, complete chat histories, and full admin command execution.

Root cause: OpenClaw's default configuration did not require authentication.

Microsoft's February 2026 research on "AI Recommendation Poisoning" and Trend Micro's analysis highlight threats specific to persistent AI agents:

- Indirect Prompt Injection: Malicious instructions hidden in webpages, emails, or documents. When OpenClaw fetches content, embedded instructions can hijack its behavior.
- Memory Poisoning: Attackers corrupt persistent memory files, causing malicious behavior across future sessions. OpenClaw stores memory in plaintext Markdown -- any file access enables persistent compromise.
- Cascading Failures: A compromised skill or poisoned memory propagates through every subsequent decision.
- AI Recommendation Poisoning: Companies embedding hidden instructions in content to manipulate agent recommendations and purchasing decisions.

ClawHub functions as an unvetted app store with direct system access:

- No skill signing or provenance verification
- No automated malware scanning
- No reputation system for skill authors
- Skills can request arbitrary permissions including shell access
- 12% compromise rate demonstrates the scale

Check Point's 2026 report calls skill poisoning "the new zero-day threat in AI systems."

OpenClaw's attack surface spans seven distinct layers. Traditional security tools address Layers 1-2 at best. Layers 3-7 are entirely unmonitored in virtually every deployment.

LAYER 1: NETWORK EXPOSURE

Gateway binding, WebSocket interface, Control UI, reverse proxy configuration, TLS termination. Default configs often expose these without authentication.

LAYER 2: AUTHENTICATION & AUTHORIZATION

Gateway auth tokens, device pairing, scope management, session keys. Weak or missing auth was the #1 finding across exposed instances.

LAYER 3: CONFIGURATION SECURITY

Hardcoded API keys, model allowlists, exec security policies, tool permissions. The config file is both the single point of control and single point of failure.

LAYER 4: SKILL & PLUGIN SECURITY

Skill provenance, exec overrides, elevated permissions, malicious skill detection. ClawHub's ecosystem compounds this with supply chain risk.

LAYER 5: FILE & MEMORY EXPOSURE

MEMORY.md credentials, .env files, private keys, workspace permissions. Persistent memory is both the agent's strength and its vulnerability.

LAYER 6: AGENT BEHAVIOR

Prompt injection via fetched content, memory poisoning, cascading failures, autonomous action without guardrails.

LAYER 7: OPERATIONAL SECURITY

Version management, drift detection, credential rotation, audit logging. Most deployments have zero ongoing security monitoring.

This seven-layer gap is what ClawScan was built to fill.

The OpenClaw security crisis is the leading edge of a permanent shift in how AI agents interact with critical systems.

MARKET SIGNALS:

- Cisco: 50%+ of enterprise respondents concerned about model manipulation and behavioral drift
- Gartner: 30% of enterprises will deploy autonomous AI agents by 2028
- AI agent security market projected at \$8.2B by 2028
- MSPs already deploying OpenClaw for client environments

WHY THIS MATTERS NOW:

1. AGENT SPRAWL IS INEVITABLE

OpenClaw went from 0 to 180K deployments in weeks. Enterprise adoption will follow. Every deployment is an unmonitored attack surface.

2. TRADITIONAL SECURITY DOESN'T COVER IT

Firewalls, EDR, and SIEM don't understand prompt injection, memory poisoning, skill supply chain attacks, or autonomous privilege escalation. Purpose-built tools are required.

3. COMPLIANCE IS COMING

China issued formal warnings. EU AI Act provisions will apply. NIST is developing AI security frameworks. Organizations deploying agents without security tooling face regulatory exposure.

4. ATTACK ECONOMICS FAVOR ATTACKERS

One malicious skill compromises thousands simultaneously. One poisoned email hijacks an agent with full system access. ROI for attackers is orders of magnitude higher than traditional phishing.

5. MSP AND ENTERPRISE OPPORTUNITY

MSPs need standardized security baselines. Enterprises need continuous monitoring with drift detection. Both need automated remediation without deep OpenClaw expertise.

-
- Enable gateway auth with a strong token (32+ chars): `openclaw security audit --fix`
 - Bind gateway to localhost only (never 0.0.0.0)
 - Set file permissions: `chmod 700 ~/.openclaw`, `chmod 600` on config files
 - Configure model allowlist (restrict to models you actually use)
 - Run `openclaw security audit --deep` weekly
 - Update to the latest version immediately

- Put external access behind a reverse proxy (NGINX/Caddy) with TLS
- Enable rate limiting on gateway auth (10 attempts / 60s lockout)
- Set exec security to "deny" or "allowlist" (never "full")
- Audit installed skills -- remove any from unknown sources
- Disable browser control if not needed
- Configure DM policies: pairing mode for new contacts
- Remove plaintext passwords from `MEMORY.md` and config files
- Enable disk encryption (FileVault/LUKS/BitLocker)

- Run OpenClaw in a hardened Docker container (non-root, read-only FS)
- Implement credential isolation (Composio or similar)
- Set up continuous security monitoring with drift detection
- Configure alert routing for security regressions
- Implement automated credential rotation (tokens every 90 days)
- Deploy separate gateways for different trust boundaries
- Enable audit logging for all agent actions
- Schedule automated scans (daily baseline, weekly deep)
- Review cron jobs for elevated privileges and injection vectors
- Monitor ClawHub for security advisories

ClawScan is the first purpose-built security scanner designed specifically for OpenClaw deployments. Built as a native OpenClaw skill, it installs in one command and runs 24+ security checks across every layer of the agent attack surface.

INSTALL: `openclaw skill install clawscan`

WHAT CLAWSCAN CHECKS:

- Config Security (7 checks, 40 pts): API key exposure, gateway auth, binding, model allowlists, exec policies
- File Exposure (4 checks, 25 pts): Memory passwords, .env secrets, private keys, permissions
- Skill Security (4 checks, 20 pts): Source verification, exec overrides, elevated permissions
- Network Security (3 checks, 15 pts): Gateway exposure, webhook HTTPS, browser cookies
- OpenClaw-Specific (6 checks, 30 pts): Auth strength, cron auditing, memory protection, version currency

PURE BASH: Zero dependencies. Runs on any Unix system. No Python, no Docker, no configuration needed.

A-F GRADING: Percentage-based scoring with JSON + text output. CI/CD integration ready.

TIERS:

- Free: 24 checks, A-F grading, text + JSON output
- Pro (\$19/mo): 40+ checks, trend tracking, severity scoring, deep OpenClaw checks
- Managed (\$49/mo): Continuous drift monitoring, auto-remediation with rollback, alerting via Telegram/Discord/Slack, monthly security digests

SELF-UPDATING: Rule library updates automatically as new threats emerge.

Visit clawscan.app for documentation and pricing.

OpenClaw represents a paradigm shift in personal computing. For the first time, individuals and organizations can deploy truly autonomous AI agents with persistent memory, broad tool access, and real-world action capabilities. The adoption curve -- 0 to 180,000+ deployments in weeks -- confirms the demand.

But the security landscape has not kept pace. The first month produced a critical CVE, hundreds of malicious skills, tens of thousands of exposed instances, and million-record breaches. Nation-states are issuing warnings. Security firms are publishing crisis analyses. Most deployments remain completely unmonitored.

THE CORE PROBLEM:

Traditional security tools were not designed for autonomous AI agents. They don't understand prompt injection, memory poisoning, skill supply chain attacks, or agent configuration drift. A new category of security tooling is required.

THE PATH FORWARD:

1. Immediate: Run openclaw security audit --deep on every deployment. Fix critical findings today.
2. Short-term: Install ClawScan for continuous monitoring and A-F grading.
3. Medium-term: Implement defense-in-depth with containerization, credential isolation, and automated remediation.
4. Long-term: Adopt agent security as a core discipline alongside traditional InfoSec.

The organizations and individuals who take agent security seriously now will be the ones still operating safely when the next wave of adoption hits.

The tools exist. The best practices are documented. The only missing ingredient is action.

For enterprise inquiries: clawscan.app

This white paper is published by ClawScan for informational purposes. All vulnerability data is sourced from public disclosures, security advisories, and published research.

February 2026 | Version 1.0